Admin By Request from zero to production: remove local admin rights with just-in-time elevation

An expert, end-to-end playbook for replacing standing local administrator rights with Admin By Request: why permanent admin and total lockdown both fail, licensing and the free plan, portal SSO, the Entra ID Connector, Run As Admin vs Admin Session policy with approval and MFA, application control and malware scanning, Intune deployment for Windows and macOS, removing existing local admins, pilot to rollout, audit, troubleshooting and rollback.

9 phases | 28 steps | Tick each item when its "done when" criterion is true

Phase 1 Plan: measure admin sprawl, choose the elevation model and the plan about 2–4 days

- [ ] **1.1 Measure who holds local admin today, and how they got it**
  A list per device class shows every account and group in the local Administrators group, with the mechanism that put it there (Entra join, Entra role, GPO, Intune, manual)
- [ ] **1.2 Map personas to Run As Admin, Admin Session or nothing**
  Each persona (for example office staff, developers, engineers, IT support, external staff) has a decision: Run As Admin with or without approval, Admin Session with MFA, or no elevation at all
- [ ] **1.3 Choose the plan, check licensing and the data location**
  The licence plan matches the device count, the support expectation is explicit, and the tenant's data location and retention are recorded for your privacy assessment

Phase 2 Secure the portal: admins, SSO, privacy and retention about 1 day

- [ ] **2.1 Move portal sign-in to Entra ID and scope portal rights**
  Every portal user is a named person signing in with Microsoft 365 / Entra ID single sign-on, rights are scoped per role, and one emergency portal login is documented
- [ ] **2.2 Set privacy collection and audit retention before the first endpoint reports**
  Privacy toggles and the retention period match the privacy assessment, and the decision is recorded
- [ ] **2.3 Brand the client and publish a code of conduct**
  Users see your company name, a short code of conduct and the service desk contact in the elevation dialogs

Phase 3 Connect Entra ID and design the group model about 1 day

- [ ] **3.1 Create the Entra ID Connector app registration**
  The connector shows a green check mark in the portal, the app has only the Graph application permission `Directory.Read.All` with admin consent, and the secret has an owner and a renewal date
- [ ] **3.2 Settle hybrid identity behaviour**
  For hybrid devices you have chosen `Prefer Active Directory` or `Prefer Entra ID / Azure AD` and tested one device of each join type
- [ ] **3.3 Design global settings as the safe catch-all and sub-settings per persona**
  Global settings are the most restrictive profile, every persona from phase 1 has an Entra group, and a test user who belongs to no group gets the restrictive behaviour

Phase 4 Build the elevation policy: authorisation, MFA and lockdown about 2–3 days

- [ ] **4.1 Set authorisation: Run As Admin, Admin Session, approval, reason and time**
  For global and each sub-setting, `Allow Run As Admin`, `Require approval`, `Require reason`, `Allow Admin Sessions` and `Access time (minutes)` are set deliberately and documented
- [ ] **4.2 Require MFA for elevation through Entra ID**
  Personas that may start Admin Sessions authenticate with Entra ID MFA at elevation, and the email-matching mode is chosen deliberately
- [ ] **4.3 Lock down what elevation may touch**
  Lockdown settings for admin rights, Run As Admin, Admin Session, device owner and Intune compliance are set per persona, and the excluded-accounts list contains only named break-glass or service accounts
- [ ] **4.4 Give each persona its sub-setting**
  Each persona group has a sub-setting whose differences from global settings are written down in one line each

Phase 5 Application control and malware scanning about 1–2 days, then ongoing

- [ ] **5.1 Configure malware detection before the first elevation**
  `Real-time detection` and `Cloud scan unknown files` are set according to your data policy, the `Action` is chosen, and malware notifications reach the SOC
- [ ] **5.2 Pre-approve known-good software with rename-proof protection**
  The common installers and admin tools of each persona are pre-approved with a protection other than `No protection`, and trivial entries do not flood the audit log
- [ ] **5.3 Block the dangerous, then tune machine learning and AI approval**
  Block rules cover tools you never want elevated, and the machine-learning and AI approval thresholds are set consciously rather than left at defaults

Phase 6 Deploy the agent with Intune (Windows and macOS) about 1–2 days

- [ ] **6.1 Package the Windows client as a Win32 app**
  A Win32 app with a file-version detection rule installs the MSI in system context, and the uninstall command works on any installed version
- [ ] **6.2 Decide who owns agent versions: Intune or Auto-Update**
  Exactly one mechanism updates the agent on each platform, and the Intune app is aligned with that decision
- [ ] **6.3 Open the network path and handle proxies**
  Pilot devices show `Operational Status` and `Cloud Connectivity` as OK in the client's Connectivity panel from office, VPN and home networks
- [ ] **6.4 Deploy the macOS client: profile first, package second**
  On target Macs the EPM configuration profile reports success before the package installs, and the menu-bar icon shows a standard user after install

Phase 7 Pilot, remove existing local admins, roll out in waves about 3–6 weeks

- [ ] **7.1 Run an observe-then-enforce pilot**
  A pilot of 20–50 users across all personas has run for at least two weeks, first observing then enforcing, and its audit data has been turned into pre-approvals and sub-setting changes
- [ ] **7.2 Remove existing local admins and stop new ones appearing**
  On enforced devices the local Administrators group contains only the built-in account (managed by LAPS or disabled), named exclusions and intended Entra roles; new Entra joins no longer add the user
- [ ] **7.3 Roll out in waves with communication and support ready**
  Each wave has a date, a communication sent beforehand, approvers on call for the first days, and a go/no-go based on the pilot metrics

Phase 8 Operate: audit, reporting, SIEM and proof that admin rights are gone about Ongoing

- [ ] **8.1 Work the audit log and stop risky sessions remotely**
  Approvers review the audit log weekly, and the team can terminate a running elevation from the portal
- [ ] **8.2 Stream events to the SIEM and ticketing**
  Elevation requests, approvals and alerts arrive in the SIEM within minutes, and API keys and webhook endpoints have owners
- [ ] **8.3 Prove the result with offensive tooling and hardening checks**
  A repeat of the phase 1 measurement shows no standing local admin for everyday users, and the residual admin paths are documented exceptions

Phase 9 Troubleshooting and rollback about Ongoing

- [ ] **9.1 Triage install, connectivity and policy problems**
  The runbook lists, in order: Intune device-level install status, client Connectivity panel, Diagnostics, licence count, applied sub-setting and local policy overrides
- [ ] **9.2 Roll back safely, smallest step first**
  For a problem the team can, in order: relax the affected sub-setting, unlock a single device, and uninstall from a group — and knows how each device regains an admin path

Owner	Change / ticket	Date completed

Original checklist by Tenant Recipes, an independent project not affiliated with Microsoft or any vendor. Every step, its actions, pitfalls and the official sources it was checked against are on https://tenantrecipes.github.io/guides/admin-by-request-endpoint-privilege.html. Time estimates

are our own planning figures. Confirm against the linked sources and test in a pilot before production.